Dossier de sécurité & modélisation des menaces — FileFlow

Titre	Dossier de sécurité et modélisation des menaces
Produit	FileFlow — plateforme de partage de fichiers auto-hébergée
Version	1.1
Date	27 octobre 2026
Statut	Validé
Propriétaire	Driss OUAAZIZ — Software Architect
Contributeurs	Driss OUAAZIZ — Software Architect
Classification	Interne

Table des matières

1. Objet et périmètre
2. Description des actifs
3. Hypothèses de confiance et surface d'attaque
4. Modélisation des menaces (STRIDE)
5. Matrice de risques
6. Mesures de sécurité par domaine
7. Correspondance avec l'OWASP Top 10 (2021)
8. Résultats des scans et tests de sécurité
9. Risques acceptés
10. Recommandations et plan d'amélioration
11. Références

1. Objet et périmètre

1.1 Objet

Le présent dossier formalise l'analyse de sécurité de FileFlow. Il documente les actifs à protéger, la surface d'attaque, les menaces identifiées selon la méthode STRIDE, les contrôles en place, les risques résiduels et le plan d'amélioration. Il constitue la pièce de référence pour l'homologation de sécurité du produit et pour l'analyse de risques conduite selon la démarche EBIOS Risk Manager de l'ANSSI et la norme ISO/IEC 27005.

1.2 Périmètre

Le périmètre couvre :

- le service applicatif FileFlow (API back-end en Rust, interface web en React) ;
- l'image de conteneur de production et son socle d'exécution ;

- les données persistées (base de configuration, arborescence de fichiers, journal d'audit, secrets) ;
- la chaîne d'intégration continue au titre des contrôles de sécurité automatisés.

Sont hors périmètre : l'infrastructure d'hébergement de l'organisation déployante (réseau, terminaison TLS, sauvegardes système, durcissement de l'hôte), qui relève de la responsabilité de l'exploitant et fait l'objet du dossier d'exploitation (DEX).

1.3 Méthodologie

L'analyse combine :

- l'identification et la valorisation des actifs (chapitre 2) ;
- la définition des hypothèses de confiance et de la surface d'attaque (chapitre 3) ;
- la modélisation des menaces par la grille STRIDE de Microsoft (chapitre 4) ;
- la cotation des risques par une matrice probabilité × impact (chapitre 5) ;
- la vérification de la couverture face à l'OWASP Top 10 2021 (chapitre 7) ;
- la validation par des campagnes de tests automatisés outillés (chapitre 8) ;
- la revue de code manuelle : l'audit de sécurité d'octobre 2026 (document 14) a relevé des faiblesses de contrôle d'accès qu'aucun outil automatisé ne détectait (constats H1, H2, M1 à M4, F1 à F5). Tous ces constats sont corrigés ; la présente version 1.1 en intègre les mesures. Les constats encore ouverts (N1 à N6) sont repris aux chapitres 9 et 10, et la vérification continue est organisée par le plan directeur des scans et rapports de sécurité (document 15).

Dans la suite du document, les références H1, H2, M1… précédées de la mention « constat » désignent les constats du document 14 ; les hypothèses de confiance du chapitre 3 conservent leur numérotation propre.

---

2. Description des actifs

RÉF.	ACTIF	NATURE	SENSIBILITÉ	IMPACT EN CAS DE COMPROMISSION
A1	Comptes utilisateurs	Identifiants, empreintes de mots de passe (bcrypt), rôles, appartenance aux groupes	Élevée	Usurpation d'identité, élévation de privilèges
A2	Fichiers utilisateurs	Contenu arbitraire déposé par les utilisateurs	Élevée à critique (selon usage)	Fuite ou altération de données métier
A3	Secret de signature JWT	Clé symétrique 256 bits	Critique	Forge de jetons de session, contournement de l'authentification
A4	Journal d'audit	Traces d'événements (utilisateur, action, ressource, adresse IP, horodatage)	Moyenne	Perte de traçabilité, atteinte à la vie privée
A5	Secrets TOTP et codes de secours	Graines d'authentification à deux facteurs, codes de récupération (bcrypt)	Élevée	Contournement du second facteur
A6	Liens de partage et demandes de dépôt	Jetons publics, empreintes de mots de passe de protection	Moyenne	Accès non autorisé aux ressources partagées

RÉF.	ACTIF	NATURE	SENSIBILITÉ	IMPACT EN CAS DE COMPROMISSION
A7	Base de configuration (SQLite)	Utilisateurs, groupes, partages, favoris, collaboration	Élevée	Accès concentré à A1, A3 (dérivé), A5, A6

3. Hypothèses de confiance et surface d'attaque

3.1 Hypothèses de confiance

- **H1** — Le produit est déployé derrière un reverse-proxy assurant la terminaison TLS ; les cookies de session sont émis avec l'attribut `Secure` en production.
- **H2** — Les en-têtes de proxy (`X-Forwarded-For` , `X-Real-IP`) ne sont exploités que lorsque l'exploitant l'active explicitement (`TRUST_PROXY_HEADERS`), le cas par défaut retenant l'adresse du pair TCP, non usurpable.
- **H3** — Le système de fichiers et la base de configuration sont accessibles au seul compte d'exécution du service ; les fichiers sensibles sont restreints en `0600` .
- **H4** — L'administrateur initial et les exploitants disposant d'un accès au système hôte sont dignes de confiance.
- **H5** — La sauvegarde et la restauration des volumes de données relèvent de l'exploitant (voir DEX).

3.2 Surface d'attaque

RÉF.	POINT D'ENTRÉE	AUTHENTIFICATION	EXPOSITION
S1	Authentification (`/api/auth/login` , `/api/auth/2fa/*`)	Publique	Externe
S2	API applicative authentifiée (fichiers, partages, collaboration, favoris, administration)	Session	Externe
S3	Liens publics de partage (`/api/s/:token`) et pages de dépôt (`/api/r/:token`)	Jeton, mot de passe optionnel	Externe
S4	Service de prévisualisation et de téléchargement de fichiers	Session	Externe
S5	Ressources statiques et point de vérification d'état (`/api/health`)	Publique	Externe
S6	Système de fichiers, base de configuration, secrets	—	Interne (hôte)

4. Modélisation des menaces (STRIDE)

La grille STRIDE recense les menaces par catégorie. Le risque résiduel est coté après application des contrôles en place, selon l'échelle du chapitre 5.

4.1 Spoofing (usurpation d'identité)

MENACE	VECTEUR	CONTRÔLE EN PLACE	RISQUE RÉSIDUEL
Vol de session	Interception ou vol de cookie	Cookie `HttpOnly`, `SameSite=Strict`, `Secure` (production) ; jeton JWT signé HS256 avec secret 256 bits	Faible
Forge de jeton	Falsification d'un JWT	Vérification de signature systématique ; secret généré par le CSPRNG du système et persisté en `0600`	Faible
Contournement du second facteur	Rejeu ou devinette du code TOTP	Jeton intermédiaire à durée de vie de 5 min ; limitation de débit dédiée au 2FA ; codes de secours stockés en bcrypt	Faible
Énumération de comptes	Analyse des temps de réponse à l'authentification	Égalisation temporelle par exécution systématique de bcrypt, y compris pour un utilisateur inconnu	Faible
Remplacement du second facteur avec une session dérobée (constat M2)	Désactivation ou réinscription de la 2FA depuis un cookie volé	Désactivation de la 2FA et régénération des codes de secours soumises au mot de passe **et** à un code (TOTP ou code de secours) ; `setup` et `confirm` refusés si la 2FA est déjà active ; rotation de session (`token_version`) à la confirmation et à la désactivation, révoquant les autres sessions	Faible
Réactivation d'un ancien jeton (constat F2)	JWT d'un compte supprimé présenté après recréation d'un compte homonyme	Version de jeton initiale tirée aléatoirement (`u64`) à la création du compte	Faible
Session laissée ouverte après déconnexion (constat M3)	Échec de la déconnexion avec un jeton révoqué ou expiré	`POST /api/auth/logout` sans authentification préalable, effaçant toujours les cookies de session et d'attente 2FA	Faible

4.2 Tampering (altération)

MENACE	VECTEUR	CONTRÔLE EN PLACE	RISQUE RÉSIDUEL
Traversée de répertoire	Chemin utilisateur manipulé (`../`, chemins absolus)	Fonction `resolve()` : normalisation des composants, confinement à la racine, blocage des entrées `.fileflow*` à toute profondeur	Faible
Contournement de périmètre par chemin non canonique (constat H1)	Segment `..` franchissant un préfixe autorisé (`/teamA/../teamB`) ; préfixe sans frontière de segment (`/proj` contre `/projects`)	Toute décision d'accès porte sur le chemin virtuel canonique (`normalize_virtual` : `..` rejeté, `.` et barres multiples supprimés) ; comparaison par segments (`path_covers`) ; chemins de groupe canonicalisés à l'écriture, entrées héritées mal formées sans effet (`canonical_prefix`) ; chemins persistés stockés sous forme canonique (ADR-0008)	Faible
Évasion par lien symbolique	Lien pointant hors de la racine	Canonicalisation et revérification du confinement pour toute cible existante	Faible
Dépôt de nom de fichier malveillant	Nom contenant séparateurs ou caractères de contrôle	`sanitize_name` : neutralisation des séparateurs et des caractères de contrôle	Faible

MENACE	VECTEUR	CONTRÔLE EN PLACE	RISQUE RÉSIDUEL
Écrasement de fichier par dépôt public	Dépôt anonyme portant le nom d'un fichier existant	Réservation atomique du nom (`create_new`) puis renommage ; numérotation en cas de collision (`rapport (1).txt`) ; jamais d'écrasement	Faible
Altération concurrente de l'état	Écritures simultanées sur la corbeille ou les métadonnées	Verrous d'exclusion sur les opérations de corbeille et de métadonnées	Faible

4.3 Repudiation (répudiation)

MENACE	VECTEUR	CONTRÔLE EN PLACE	RISQUE RÉSIDUEL
Déni d'une action sensible	Absence de trace	Journal d'audit horodaté couvrant authentification, opérations sur fichiers, partages et administration	Faible
Falsification de l'adresse source dans les traces	En-tête `X-Forwarded-For` usurpé	En-têtes de proxy ignorés par défaut ; repli sur l'adresse du pair TCP	Faible
Manipulation du journal	Écriture directe sur le fichier de trace	Restriction d'accès au niveau du système de fichiers (voir H3) ; risque résiduel documenté au chapitre 9	Moyen

4.4 Information disclosure (divulgation d'information)

MENACE	VECTEUR	CONTRÔLE EN PLACE	RISQUE RÉSIDUEL
XSS stocké via un fichier	Fichier HTML/SVG/XML servi comme contenu actif	Rétrogradation en `text/plain` des contenus actifs ; en-tête `nosniff` ; CSP stricte (`script-src 'self'`) ; assainissement DOMPurify côté client	Faible
Exposition de secrets dans les réponses	Renvoi d'empreintes ou de secrets	Vues d'API expurgées (jamais d'empreinte de mot de passe ni de secret TOTP)	Faible
Injection de formule via export CSV	Export du journal d'audit ouvert dans un tableur	Neutralisation des préfixes de formule dans les champs CSV	Faible
Divulgation inter-utilisateurs	Accès aux fichiers internes d'un autre utilisateur	Blocage des chemins `.fileflow*` (corbeille, versions, secrets) ; contrôle d'accès par chemin canonique	Faible
Lien public détaché de sa ressource (constat F5)	Lien survivant au renommage, au déplacement ou à la suppression, puis exposant un fichier recréé au même chemin ; lien survivant au retrait des droits du créateur	Liens publics et demandes de dépôt re-pointés au renommage/déplacement et purgés à la suppression ; à chaque téléchargement, revérification que le créateur est actif et dispose toujours de la lecture (sinon 404 uniforme)	Faible

MENACE	VECTEUR	CONTRÔLE EN PLACE	RISQUE RÉSIDUEL
Dépassement du plafond de téléchargements (constat F1)	Requêtes parallèles ou téléchargement par plages (`Range`) sur un lien à usage limité	Réservation atomique (contrôle et incrément sous un même verrou, restitution si l'envoi échoue) ; en-tête `Range` ignoré pour les liens plafonnés	Faible
Force brute sur le mot de passe d'un lien public (constat M4)	Devinette d'un code court sur `/s/:token` ou `/r/:token`	Limiteur dédié sur deux clés (lien, IP) : 5 échecs → 15 min, réponse 429, contrôle avant `bcrypt` ; sur les dépôts, mot de passe exigé avant tout fichier	Faible
Publication d'un lien public par un destinataire de partage interne (constat ouvert N5)	Un utilisateur ayant reçu une ressource en lecture crée un lien public anonyme	Création soumise à `validate_access(FileRead)` ; lien borné et révoqué avec les droits du créateur ; **arbitrage produit en attente** (chapitre 9)	Modéré

4.5 Denial of service (déni de service)

MENACE	VECTEUR	CONTRÔLE EN PLACE	RISQUE RÉSIDUEL
Épuisement mémoire au téléchargement groupé	Archive volumineuse assemblée en mémoire	Archive écrite dans un fichier temporaire puis diffusée en flux (temp + suppression immédiate) ; plafond de 2 Gio ; sémaphore de concurrence	Faible
Épuisement mémoire à l'envoi	Fragment d'envoi surdimensionné	Plafond de taille par fragment ; réaping des sessions d'envoi inactives	Faible
Force brute sur l'authentification	Tentatives répétées de connexion ou de 2FA	Verrouillage à trois niveaux (ADR-0006) : IP (5 échecs), couple utilisateur/IP (5 échecs), compte toutes IP (50 échecs, non remis à zéro par une connexion réussie), 15 min ; limiteur dédié à l'étape 2FA	Faible
Verrouillage ciblé d'un compte par un tiers (constat F3)	Saisie volontaire de mauvais mots de passe sur le compte d'autrui	Le verrou bas (5) porte sur le couple utilisateur/IP : un tiers ne bloque que lui-même ; bloquer le compte exige ~50 échecs répartis sur au moins 10 adresses	Faible
Verrouillage d'un lien public par un tiers (constat ouvert N1)	Cinq mauvais mots de passe sur un lien protégé dont l'URL est connue	Verrou limité à 15 min ; **arbitrage en attente** entre protection des codes courts et disponibilité du lien (chapitre 9)	Faible
Perte de l'administration (constat F4)	Rétrogradation, désactivation ou suppression du dernier administrateur actif	Refus (400) si l'opération laisse l'instance sans administrateur actif (un administrateur désactivé ne compte pas) ; contrôle effectué sous le même verrou que la modification	Faible
Saturation par dépôt public	Dépôts volumineux sur une page `/r/:token`	Plafond dédié `PUBLIC_UPLOAD_MAX_MB` (100 Mio par défaut, borné par `MAX_UPLOAD_MB`) ; écriture en flux sur disque ; quota du créateur ; nettoyage des fichiers temporaires en cas d'erreur	Faible
Arrêt du processus par panique	Entrée provoquant une panique dans un gestionnaire	Construction d'en-têtes faillible (pas de `unwrap` sur données externes) ; fuzzing des analyseurs d'entrée (chapitre 8)	Faible

4.6 Elevation of privilege (élévation de privilèges)

MENACE	VECTEUR	CONTRÔLE EN PLACE	RISQUE RÉSIDUEL
Contournement du contrôle d'accès	Appel direct d'une opération protégée	Point de contrôle unique `validate_access`, sur chemin canonique : administrateur → partage interne → permissions → dossier partagé (autorité dérivée) → chemins de groupe	Faible
Escalade via un dossier partagé (constat M1)	Membre obtenant des droits supérieurs à ceux du créateur, ou les conservant après sa révocation	Autorité dérivée (ADR-0008) : un membre n'obtient jamais plus que le droit propre du créateur (`own_grant` : rôle, permissions, groupes), réévalué à chaque accès ; création soumise à `own_grant(FileRead)`, octroi de l'écriture à `own_grant(FileWrite)`	Faible
Écriture via une demande de dépôt public (constat H2)	Utilisateur en lecture seule créant une page de dépôt pour écrire dans un dossier	Création soumise au droit d'écriture **propre** (`validate_own_access(FileWrite)`) ; droit revérifié à chaque dépôt (sinon 404)	Faible
Re-partage transitif abusif	Partage d'une ressource reçue par partage	`validate_own_access` : le partage exige un accès propre (rôle, permissions, groupe), excluant les droits obtenus par partage	Faible
Persistance de session après changement de droits	Jeton conservant un rôle obsolète	Révocation par incrément du numéro de version de jeton (`tv`) lors des changements de mot de passe, de rôle, de permissions, de statut, d'activation ou de désactivation de la 2FA, ou de déconnexion globale (ADR-0002)	Faible
Élévation par dépôt d'exécutable	Dépôt d'un fichier de type dangereux	Liste de blocage d'extensions à l'envoi (authentifié et public)	Faible

5. Matrice de risques

5.1 Échelles

Probabilité — 1 Rare · 2 Peu probable · 3 Possible · 4 Probable · 5 Très probable. **Impact** — 1 Négligeable · 2 Mineur · 3 Modéré · 4 Majeur · 5 Critique.

5.2 Niveaux de risque (probabilité × impact)

SCORE	NIVEAU	TRAITEMENT ATTENDU
1–4	Faible	Acceptable, surveillance
5–9	Modéré	Réduction planifiée
10–14	Élevé	Réduction prioritaire
15–25	Critique	Traitement immédiat

5.3 Cotation des risques résiduels

RÉF.	RISQUE	PROBABILITÉ	IMPACT	SCORE	NIVEAU
R1	Compromission du secret JWT (accès hôte)	1	5	5	Modéré

RÉF.	RISQUE	PROBABILITÉ	IMPACT	SCORE	NIVEAU
R2	Traversée de répertoire / évasion symlink	1	4	4	Faible
R3	XSS via fichier prévisualisé	1	4	4	Faible
R4	Force brute sur l'authentification	2	3	6	Modéré
R5	Contournement du contrôle d'accès	1	4	4	Faible
R6	Déni de service applicatif	2	3	6	Modéré
R7	Altération du journal d'audit (accès hôte)	1	3	3	Faible
R8	Vulnérabilité d'une dépendance tierce	2	3	6	Modéré
R9	Verrouillage d'un compte ou d'un lien public par un tiers (N1)	2	2	4	Faible
R10	Lien public créé par un destinataire de partage interne (N5)	2	3	6	Modéré
R11	Chaîne de construction non figée : image Node.js hors support, images de base non épinglées par empreinte, chaîne Rust non figée en CI (N2 à N4)	2	3	6	Modéré

Aucun risque résiduel n'est coté Élevé ou Critique. Avant correction, les constats H1 et H2 de l'audit d'octobre 2026 (contournement du contrôle d'accès, écriture par un utilisateur en lecture seule) relevaient du niveau Élevé ; leur traitement (ADR-0008) ramène R2 et R5 au niveau Faible. Le traitement du constat F3 (ADR-0006, révisé) ramène le verrouillage ciblé d'un compte au niveau Faible (R9). Les risques Modérés font l'objet de mesures de réduction décrites aux chapitres 6 et 10, ou d'un arbitrage en attente au chapitre 9.

---

6. Mesures de sécurité par domaine

6.1 Authentification

- Authentification par jeton JWT porté par un cookie `HttpOnly`, `SameSite=Strict` et `Secure` (paramétrable pour le déploiement local en HTTP).
- Signature HS256 avec un secret de 256 bits issu du générateur cryptographique du système, persisté avec des droits `0600`.
- Empreintes de mots de passe en bcrypt ; égalisation temporelle pour prévenir l'énumération de comptes.
- Second facteur TOTP optionnel, assorti de codes de secours stockés en bcrypt. Désactiver la 2FA ou régénérer les codes de secours exige le mot de passe **et** un code valide ; l'activation et la désactivation font tourner la session.
- Révocation immédiate de l'ensemble des sessions par le mécanisme de version de jeton (`tv`), dont la valeur initiale est aléatoire à la création du compte.
- Déconnexion toujours effective : `POST /api/auth/logout` ne requiert pas de session valide et efface les cookies de session et d'attente 2FA.
- Verrouillage des connexions à trois niveaux, 15 minutes : par IP (5 échecs), par couple utilisateur/IP (5 échecs) et par compte toutes IP confondues (50 échecs, compteur non remis à zéro par une connexion réussie). Verrous en mémoire, purgés périodiquement (ADR-0006).

6.2 Autorisation

- Modèle RBAC : rôles, permissions directes et groupes porteurs de chemins autorisés.

- Point de contrôle unique `validate_access`, évalué sur le chemin virtuel canonique dans l'ordre : administrateur, partage interne, permissions résolues, appartenance à un dossier partagé (bornée par le droit propre du créateur), restriction par chemin de groupe (comparaison par segments).
- `validate_own_access` empêche la propagation transitive des droits par re-partage ; il conditionne la création des partages internes et des demandes de dépôt public.
- Autorité dérivée (ADR-0008) : dossiers partagés, liens publics et demandes de dépôt n'excèdent jamais les droits propres de leur créateur et sont réévalués à chaque usage ; révoquer ou rétrograder le créateur les neutralise immédiatement.
- Refus de création d'un droit ou d'un lien persistant sur une ressource atteinte par un lien symbolique.
- Garde du dernier administrateur actif : rétrogradation, désactivation et suppression refusées si elles laissent l'instance sans administrateur actif.

6.3 Gestion des fichiers

- Résolution de chemin confinée à la racine, blocage des entrées internes `.fileflow*` à toute profondeur, confinement des liens symboliques par canonicalisation.
- Canonicalisation des chemins virtuels avant toute décision d'accès (`..` rejeté) ; chemins persistés stockés sous forme canonique.
- Assainissement des noms de fichiers ; liste de blocage d'extensions à l'envoi.
- Partages internes, dossiers partagés, favoris, liens publics et demandes de dépôt re-pointés lors d'un renommage ou d'un déplacement, et purgés (avec les métadonnées) lors d'une suppression.
- Rétrogradation en `text/plain` des contenus susceptibles d'être exécutés par le navigateur.

6.4 En-têtes et sécurité navigateur

- Politique de sécurité de contenu (CSP) stricte ; `X-Content-Type-Options: nosniff` ; `X-Frame-Options` ; `Referrer-Policy` ; `Strict-Transport-Security` lorsque les cookies sécurisés sont actifs.
- Absence de CORS permissif.
- Construction faillible des en-têtes `Content-Disposition`, sans provoquer de panique sur donnée externe.
- Assainissement DOMPurify du rendu côté client.

6.5 Données au repos

- Base de configuration et secrets restreints en `0600`.
- Recommandation d'un chiffrement du volume au niveau de l'hôte pour les déploiements traitant des données sensibles (voir chapitre 10).

6.6 Journalisation

- Journal d'audit horodaté, en ajout continu, avec rotation à taille bornée.
- Protection contre l'injection de formule à l'export CSV.

6.7 Résilience et lutte contre le déni de service

- Plafonds de taille (envoi, fragment, téléchargement groupé) et sémaphore de concurrence sur l'assemblage des archives.
- Diffusion en flux avec suppression immédiate du fichier temporaire.
- Limitation de débit sur les points d'authentification et sur les mots de passe des liens publics.

- Plafond spécifique aux dépôts publics (`PUBLIC_UPLOAD_MAX_MB`, 100 Mio par défaut, borné par `MAX_UPLOAD_MB`, lui-même de 200 Mio par défaut).

6.8 Liens publics et demandes de dépôt

- Revérification à chaque téléchargement que le créateur du lien est actif et conserve la lecture ; à chaque dépôt, que le créateur conserve l'écriture. Réponse 404 uniforme dans le cas contraire.
- Plafond de téléchargements appliqué de façon atomique ; en-tête `Range` ignoré pour les liens plafonnés (les liens sans plafond servent toujours les plages, réponse 206).
- Mots de passe protégés par un limiteur à deux clés (`link:<jeton>` et `ip:<adresse>`) : 5 échecs → 15 minutes, réponse 429 ; un succès n'efface que la clé du lien.
- Dépôts : mot de passe exigé avant les fichiers dans le formulaire, écriture en flux dans des fichiers temporaires nettoyés en cas d'erreur, nom réservé atomiquement et numéroté en cas de collision.

---

7. Correspondance avec l'OWASP Top 10 (2021)

RÉF.	CATÉGORIE	STATUT	COUVERTURE
A01	Contrôle d'accès défaillant	Couvert	Point de contrôle unique sur chemins canoniques, comparaison par segments ; autorité dérivée des délégations (ADR-0008) ; `validate_own_access` ; garde du dernier administrateur. Constat ouvert N5 (chapitre 9)
A02	Défaillances cryptographiques	Couvert	Secret 256 bits ; bcrypt ; HS256 ; secrets restreints en `0600`
A03	Injection	Couvert	Requêtes SQL paramétrées ; anti-traversée ; anti-XSS ; anti-injection de formule CSV
A04	Conception non sécurisée	Couvert	Modélisation STRIDE ; limitation de débit ; conception des partages (autorité dérivée, rattachement au cycle de vie des ressources) ; revue de code manuelle (document 14)
A05	Mauvaise configuration de sécurité	Couvert	En-têtes de sécurité ; absence de CORS permissif ; socle d'exécution minimal
A06	Composants vulnérables et obsolètes	Couvert	Analyse continue des dépendances (cargo-audit, cargo-deny, pnpm audit, Trivy) et mises à jour Dependabot (chapitre 8). Image de build Node.js hors support : constat ouvert N2
A07	Défaillances d'identification et d'authentification	Couvert	Révocation `tv` (valeur initiale aléatoire) ; verrouillage à trois niveaux ; limitation des mots de passe de liens publics ; 2FA avec réauthentification pour toute modification du second facteur ; égalisation temporelle
A08	Défaillances d'intégrité logicielle et des données	Couvert	Désérialisation typée ; restauration de version confinée ; sources de dépendances restreintes à crates.io (cargo-deny) ; actions CI épinglées par empreinte de commit. Images de base et chaîne Rust non figées : constats ouverts N3 et N4
A09	Défaillances de journalisation et de supervision	Couvert	Journal d'audit ; rotation ; recommandations de supervision (voir doc d'observabilité)
A10	Falsification de requête côté serveur (SSRF)	Sans objet	Aucun appel sortant vers une URL fournie par l'utilisateur

---

8. Résultats des scans et tests de sécurité

8.1 Contrôles automatisés en intégration continue

Les contrôles suivants sont intégrés à la chaîne d'intégration continue. Le flux `ci` s'exécute à chaque poussée et demande de fusion ; le flux `security` à chaque poussée et demande de fusion ainsi que chaque lundi à 06:00 UTC, afin de faire remonter les avis publiés sur des dépendances inchangées. Tout constat est bloquant.

OUTIL	FLUX	PÉRIMÈTRE	ÉTAT SUR `CA27C96`
semgrep	security	Analyse statique, jeux de règles OWASP Top 10, Rust, TypeScript, React et secrets	0 constat
ESLint (règles de sécurité)	ci	Front-end : `eslint-plugin-security`, `eslint-plugin-no-unsanitized` ; puits XSS et expressions rationnelles vulnérables au ReDoS (`detect-unsafe-regex`) en erreur	0 erreur
clippy	ci	Back-end, `-D warnings` ; `unwrap_used`, `dbg_macro` et `todo` bloquants hors tests	0 avertissement
cargo-audit	security	Avis RustSec sur les dépendances Rust	0 exploitable (2 avis acceptés, voir chapitre 9)
cargo-deny	security	Avis, licences en liste blanche (licences permissives), sources limitées à crates.io, crates `zstd` et `bzip2` bannies	Conforme
pnpm audit	security	Dépendances front-end de production	0 vulnérabilité
Trivy — système de fichiers	security	Dépendances, secrets, mauvaises configurations (verrous Cargo/pnpm, Dockerfile)	0 / 0 / 0
Trivy — image	security	Couches de l'image d'exécution (base musl / distroless static) ; échec sur toute vulnérabilité Critique ou Élevée corrigeable	0
gitleaks	security	Historique Git complet	0 secret divulgué
cargo-fuzz / libFuzzer	security (hebdomadaire)	4 analyseurs d'entrée non fiable (résolution de chemin, assainissement de nom, en-tête `Range`, `Content-Disposition`), 60 s par cible	0 panique, 0 plantage
Tests unitaires	ci	103 tests back-end, dont les non-régressions des constats du document 14 ; tests front-end	Réussis

La configuration Dependabot (`.github/dependabot.yml`) couvre les écosystèmes Cargo, npm, GitHub Actions et Docker : mises à jour hebdomadaires groupées, avec un délai de carence de 7 jours avant proposition d'une nouvelle version ; les alertes et correctifs de sécurité automatiques sont activés sur le dépôt. Les actions tierces de la chaîne CI sont épinglées par empreinte de commit.

8.2 Campagnes ponctuelles

CAMPAGNE	PÉRIMÈTRE	RÉSULTAT
OWASP ZAP (document 13)	Test dynamique de base sur instance en fonctionnement	0 échec, 5 avertissements mineurs, 62 contrôles réussis

CAMPAGNE	PÉRIMÈTRE	RÉSULTAT
Audit de sécurité d'octobre 2026 (document 14)	Revue de code manuelle orientée OWASP Top 10 / ASVS et exécution des outils du pipeline	2 constats élevés (H1, H2), 4 moyens (M1 à M4), 5 faibles (F1 à F5), 4 sur les dépendances (D1 à D4) — **tous corrigés** ; constats complémentaires N1 à N6 ouverts (chapitres 9 et 10)

L'audit d'octobre 2026 montre la limite des outils automatisés : les failles de contrôle d'accès relevées (H1, H2, M1) étaient invisibles aux analyseurs statiques. Le plan directeur des scans et rapports de sécurité (document 15) organise en conséquence la revue manuelle, une matrice d'autorisation exécutable et le DAST authentifié.

Les dépendances signalées par l'audit ont été mises à jour : `zip` 9 (sans les algorithmes `zstd` et `bzip2`), DOMPurify 3.4.17, tokio 1.54.1 ; `jsonwebtoken` reste en version 10 (HS256, backend `rust_crypto`).

---

9. Risques acceptés

9.1 Risques acceptés

RÉF.	RISQUE ACCEPTÉ	JUSTIFICATION	CONDITION DE RÉÉVALUATION
RA1	Avis RustSec RUSTSEC-2023-0071 sur la bibliothèque `rsa` (attaque temporelle Marvin)	Dépendance transitive de `jsonwebtoken` (backend `rust_crypto`) utilisée uniquement pour la signature RSA, jamais invoquée (le produit signe exclusivement en HS256) ; aucun correctif disponible ; exception justifiée dans `backend/.cargo/audit.toml` et `backend/deny.toml`	Ajout d'un usage RSA
RA1 bis	Avis RustSec RUSTSEC-2026-0387 sur `crypto-bigint` 0.5 (opérations non constantes en temps)	Dépendance transitive des courbes elliptiques ES256/ES384 de `jsonwebtoken` ; jetons exclusivement HS256 avec clés HMAC, aucune opération sur courbe elliptique exécutée ; aucune version de `jsonwebtoken` ne s'en affranchit encore ; exception justifiée dans les deux mêmes fichiers	Ajout d'un usage ECDSA, ou version de `jsonwebtoken` sans `crypto-bigint` 0.5
RA2	Binaire non-PIE (image statique)	Compromis retenu pour produire une image statique sans dépendances système et sans vulnérabilité de socle ; risque limité pour un binaire écrit dans un langage à sûreté mémoire	Évolution des exigences de durcissement
RA3	Couverture DAST partielle (test de base non authentifié)	La campagne dynamique initiale n'a couvert que la surface publique ; la surface authentifiée n'a pas encore été testée dynamiquement	Réalisation du scan actif authentifié (chapitre 10)
RA4	Intégrité du journal d'audit tributaire de l'accès hôte	Protection assurée par les droits du système de fichiers ; hors périmètre applicatif	Exigence d'inaltérabilité renforcée
RA5	Verrouillage résiduel d'un compte par une attaque distribuée	Le verrou bas porte désormais sur le couple utilisateur/IP ; le plafond par compte (50 échecs, toutes IP) reste nécessaire contre la devinette distribuée et ne peut être atteint qu'avec au moins 10 adresses. Ce compromis remplace celui de la version 1.0, où cinq échecs suffisaient à bloquer un compte (constat F3, ADR-0006 révisé)	Matérialisation d'attaques distribuées ; ajout éventuel d'un défi (CAPTCHA)

RÉF.	RISQUE ACCEPTÉ	JUSTIFICATION	CONDITION DE RÉÉVALUATION
RA6	Verrous de limitation de débit en mémoire	Perdus au redémarrage et non partagés entre instances ; acceptable pour un déploiement mono-instance	Passage à un déploiement multi-instance

9.2 Risques en attente de décision

RÉF.	CONSTAT OUVERT	OPTIONS	RISQUE
N1	Verrouillage d'un lien public protégé par un tiers : cinq mauvais mots de passe sur la clé `link:<jeton>` bloquent le lien pour tous pendant 15 minutes	(a) conserver la clé par lien, qui protège les codes courts contre une devinette répartie sur de nombreuses adresses ; (b) aligner sur la connexion : couple lien/IP au seuil normal et plafond par lien plus élevé	R9 — Faible
N5	Création d'un lien public par un destinataire de partage interne : `POST /api/shares` n'exige que `validate_access(FileRead)`, qui inclut les droits obtenus par partage	(a) exiger le droit propre (`validate_own_access`), comme pour les partages internes et les demandes de dépôt ; (b) assumer le comportement, le lien restant borné et révoqué avec les droits de son créateur	R10 — Modéré

10. Recommandations et plan d'amélioration

Le plan directeur des scans et rapports de sécurité (document 15) détaille la mise en œuvre, le phasage et les critères de mise en production associés à ces recommandations.

RÉF.	RECOMMANDATION	PRIORITÉ	DOMAINE
P1	Réaliser un scan dynamique actif authentifié de l'API (couverture de la surface interne)	Élevée	Tests
P2	Ajouter l'en-tête `Permissions-Policy` et, si l'isolation d'origine est requise, `COOP` / `COEP`	Moyenne	En-têtes navigateur
P3	Recommander et documenter le chiffrement du volume de données au niveau de l'hôte	Moyenne	Données au repos
P4	Étendre le corpus et la durée des campagnes de fuzzing	Basse	Tests
P5	Étudier une signalisation d'intégrité du journal d'audit (par exemple chaînage) pour les contextes à forte exigence	Basse	Journalisation
P6	Arbitrer les constats N1 et N5 (chapitre 9.2) et mettre à jour ADR-0006 et ADR-0008 en conséquence	Élevée	Contrôle d'accès
P7	Transformer les scripts de reproduction des constats H2, M1, M2 et M4 en tests d'intégration exécutés en CI, et outiller une matrice d'autorisation exécutable (document 15)	Élevée	Tests
P8	Remplacer l'image de build `node:20-slim` par une version de Node.js maintenue (N2)	Élevée	Chaîne de construction
P9	Épingler les images de base Docker par empreinte (`@sha256`) (N3)	Moyenne	Chaîne de construction
P10	Figer la version de la chaîne d'outils Rust en CI (N4)	Moyenne	Chaîne de construction

RÉF.	RECOMMANDATION	PRIORITÉ	DOMAINE
P11	Traiter les demandes de mise à jour Dependabot en attente, notamment les montées de version majeures (axum, React, Tailwind CSS, TypeScript, rusqlite, totp-rs, Node.js), avec revue de sécurité	Moyenne	Dépendances

11. Références

- ANSSI — *EBIOS Risk Manager*, méthode d'appréciation et de traitement des risques numériques.
- ISO/IEC 27005 — *Sécurité de l'information — Lignes directrices sur la gestion des risques liés à la sécurité de l'information*.
- OWASP — *Threat Modeling* et *Threat Modeling Process*.
- Microsoft — *The STRIDE Threat Model*.
- OWASP — *Top 10 Web Application Security Risks* (2021).
- FileFlow — ADR-0002 (révocation des jetons), ADR-0006 (limitation des tentatives d'authentification), ADR-0008 (chemins canoniques et autorité dérivée).
- FileFlow — document 13 (plan DAST OWASP ZAP), document 14 (rapport d'audit de sécurité d'octobre 2026), document 15 (plan directeur des scans et rapports de sécurité).